

6. Close off linked servers, such as FTP servers or Samba services that connect to the same system on which your database runs. Also, close unused network protocol ports, such as *telnet* and *TFTP* ports, when you don't need them. This restricts attackers trying to upload Trojans or root-kits into your system through these ports.
7. Avoid using different databases linked together by a single application, as they may create code complexity, which ultimately may create loopholes for intruders.
8. As far as passwords are concerned, keep auditing them and change them regularly. Use complex passwords that are above 16 characters in length—this makes it hard for many brute-forcing programs to crack them. You can also set password validations that ask users to enter complex passwords. Encrypt and hash passwords and other sensitive data; never store them in clear-text. Encrypting connection strings is also a good practice.
9. Add extra code in your scripts to log IP addresses that visit your site, and block suspicious IPs. You can also add scripts to show warnings like, "WARNING: Attacker, your IP address x.y.z.w has been logged. Legal action will be taken against you if your intentions are malicious."
10. If you can, use databases which are not commonly used, because they should have less known exploits against them. Regularly consult your system vendor for security and performance hot-fixes and related patches.
11. Use these tools of the security industry:
 - *SQLninja* is an automatic testing tool to exploit SQL-injection-vulnerable applications. It performs extensive DBMS back-end fingerprinting and brute forcing on account passwords. View more details at <http://www.sqlninja.sourceforge.net>.
 - *Greensql* is an open source database firewall that tries to protect against SQL injection errors. View its documentation at <http://www.greensql.net/>.
 - You can also go for the SQL injection blocking tool, *SQLblock* ODBC edition. It has an SQL injection prevention feature, which works as an ordinary ODBC/JDBC data source, and monitors

"Web App Security Checking"

To know about the present vulnerabilities of your Web applications, use scanners that notify you about any dangerous threats that your application and Web server is facing. Scanners such as *Webinspect*, *Nikto* and *Whisker* top the list. *Acunetix* also provides a trial-based commercial Web scanner that is also popular among security professionals. You can view their documentation at <http://www.web-inspect.com/>, <http://cirt.net/nikto2>, <http://www.acunetix.com/>

every SQL statement being executed. It alerts the administrator if any malicious or forbidden SQL statement is encountered.

- Since SQL injection has the dubious distinction of being the attack that any malicious attacker learns first, it is the first we have covered, and in depth. For more detailed information on SQL injection and other programming defences, don't forget to visit www.owasp.org. We will deal with cross-site scripting, command execution and many other dangerous attacks on Web applications and Apache in the next article. Meanwhile, you can send your queries and constructive feedback to [abajpai75 AT yahoo DOT com](mailto:abajpai75@Yahoo.com). Always remember: *know hacking, but no hacking.* 

Resources

- <http://www.secureteam.com/securityreviews/5DP0N1P76E.html>
- <http://feruh.mavtuna.com/makale/sql-injection-cheatsheet/>
- <http://www.nextgenss.com/papers.htm>
- Refer to Apache 2 Server Bible by Mohammed J. Kabir for more on Apache's functionality.

By: Arpit Bajpai

The author is a FOSS enthusiast and loves to troubleshoot in information security, while exploring new exploits and system vulnerabilities.

TechnoMail - Enterprise Email Server
Anti SPAM, Anti Virus, Email Content Filtering

Firewall, Internet Access Control
Content Filtering, Site Blocking

Bandwidth Management System

Managed Email Hosting Solutions

TechnoInfotech®

1, Vikas Permisses, 11 Bank Street, Fort, Mumbai, India - 400 001. Mobile: 09326087210. info@technoinfotech.com